

Politiques de cybersécurité

9567-0048 Québec inc. — 60sec-Paiement

Pièce jointe à la demande d'enregistrement d'un fournisseur de services de paiement

Banque du Canada — Loi sur les activités associées aux paiements de détail — section 11

Demandeur : 9567-0048 Québec inc., NEQ 1182124850, 102 chemin Miltimore, Sutton (Québec) J0E 2P0

Nom commercial : 60sec-Paiement

Personne désignée : Yves Perron, président-directeur général — y@le102.ca — 514-885-9351

Cadre dirigeant responsable : Yves Perron, président-directeur général

Date prévue de lancement : 1^{er} avril 2027

Version : 1.0 — 8 septembre 2026

Le présent document décrit les mesures techniques et organisationnelles qui protègent les systèmes et les données servant aux activités associées aux paiements de détail. Il précise le volet « mesures de protection » du cadre de gestion des risques opérationnels, exigé à l'alinéa 5(1)g) du Règlement sur les activités associées aux paiements de détail, et se lit avec le cadre de réponse aux incidents joint à la même section.

1. Objet, portée et articulation

La présente pièce énonce les règles que le demandeur s'impose pour protéger ses actifs opérationnels. Elle couvre les systèmes, les données, les personnes qui y accèdent et les tiers qui les hébergent ou les traitent. Chaque règle y est formulée de manière à pouvoir être **vérifiée** plutôt que seulement affirmée : la colonne « vérification » des tableaux indique, pour chacune, ce qui en établit le respect.

Pièce	Ce qu'elle établit	Rapport avec la présente
Pièce 05 cadre de gestion des risques	Les risques recensés, les objectifs d'intégrité, de confidentialité et de disponibilité, et les huit domaines de mesures de protection prévus au Règlement.	Elle énonce <i>qu'une</i> mesure existe ; la présente pièce énonce <i>laquelle</i> , et comment on le vérifie.
Pièce 06 réponse aux incidents	La gravité, les rôles, les procédures et les avis lorsqu'une mesure a cédé.	La présente pièce vise à empêcher ; celle-là, à réagir. Les deux se rejoignent aux mesures immédiates.
Pièce 07 le présent document	Les politiques applicables aux accès, aux clés, aux appareils, aux réseaux, aux correctifs, au développement, aux journaux, aux sauvegardes, aux données, aux personnes et aux tiers.	—

Ce que la présente pièce ne couvre pas

- Les contrôles proprement financiers — plafonds, double approbation des lots, retenue et réserve — qui relèvent de la conception du service et figurent aux pièces 02 et 05. La double approbation est toutefois reprise ici pour la partie qui touche aux droits d'accès.
- Le programme de lutte contre le recyclage des produits de la criminalité, joint à la section 16 de la demande.
- La sécurité physique des locaux : le demandeur n'exploite aucun point de service et ne conserve aucune donnée de production sur support local.

2. Les principes qui commandent les règles

Les règles qui suivent ne sont pas une collection de bonnes pratiques : elles découlent de six principes, et chaque exception à une règle doit être justifiée au regard du principe correspondant.

Principe	Ce qu'il commande
Refus par défaut	Un accès qui n'a pas été accordé explicitement est refusé. Aucune permission ne s'acquiert par ancienneté, par appartenance à une équipe ou par oubli de révocation.
Moindre privilège	Chaque compte, chaque clé et chaque service ne peuvent que ce que leur fonction exige, et pour la durée où elle l'exige.
Aucun réseau de confiance	Être à l'intérieur du périmètre ne confère aucun droit. Les échanges internes sont authentifiés et chiffrés comme les autres.

Principe	Ce qu'il commande
Défense en profondeur	Aucune mesure n'est supposée tenir seule. Les contrôles sont disposés de manière qu'une compromission doive en franchir plusieurs, dont au moins un qui ne repose pas sur le secret.
Le secret est périssable	Un secret se protège par sa rotation et sa révocabilité, non par sa longévité. Tout secret a une durée de vie et un moyen de le remplacer sans interruption de service.
Ce qui touche aux fonds se journalise	Toute action susceptible d'influer sur un solde, un paiement ou une donnée de contrepartie laisse une trace attribuable, conservée hors de portée de celui qui l'a produite.

3. La défense en profondeur, appliquée aux fonds

Chemin d'une compromission

Réseau et chiffrement

Chiffrement en transit, restriction des accès d'administration, cloisonnement des environnements.

Authentification

Comptes nominatifs et deuxième facteur pour les personnes ; clés à durée de vie limitée pour les applications.

Autorisation

Moindre privilège et cloisonnement par locataire : un accès obtenu ne devient pas un accès général.

Double approbation des lots

Deux personnes physiques distinctes. C'est la seule couche qui ne repose pas sur le secret.

Grand livre immuable et invariant

Une écriture ne s'efface pas ; l'invariant du grand livre refuse un état incohérent.

Journalisation et rapprochement

Ce qui a été fait demeure attribuable ; l'écart apparaît au rapprochement du jour ouvrable suivant.

Fonds des utilisateurs finaux, au compte en fiducie

Les trois premières couches reposent sur un secret — un mot de passe, un second facteur, une clé. Un attaquant qui les détient toutes les franchit. La quatrième ne repose sur aucun secret : elle exige deux identités distinctes, et elle demeure donc en travers du chemin lorsque les autres ont cédé. Les deux dernières n'empêchent rien : elles garantissent que ce qui a été fait est visible et reconstituable, ce qui borne la durée pendant laquelle une atteinte peut passer inaperçue à un jour ouvrable.

4. Gestion des accès

N°	Règle	Vérification
4.1	Tout accès aux systèmes de production se fait par un compte nominatif . Aucun compte partagé, aucun compte générique, aucun compte de service employé par une personne.	Revue trimestrielle des comptes ; tout compte non attribuable est supprimé.
4.2	L' authentification à deux facteurs est obligatoire pour tout accès de production, sans exception ni exemption temporaire.	Configuration vérifiée à la revue trimestrielle et après toute modification importante.
4.3	Les droits sont attribués par rôle , au niveau minimal requis. Les droits de préparation et d'approbation d'un lot sont distincts, et la plateforme refuse l'approbation d'un lot par le compte qui l'a préparé.	Essai de vérification des contrôles, semestriel ; tentative d'auto-approbation exécutée et refusée.
4.4	Un accès est ouvert après vérification de l'identité et formation préalable, et retiré le jour même du départ ou de la fin du mandat.	Registre des ouvertures et des retraits, rapproché de la liste des personnes actives.
4.5	Les accès d'administration ne sont employés que pour des tâches d'administration, depuis un poste conforme et une provenance restreinte. Ils ne servent jamais aux opérations courantes.	Journalisation des sessions d'administration, examinée à la revue trimestrielle.

N°	Règle	Vérification
4.6	Aucun accès d'urgence ne permet de contourner la double approbation d'un lot. Un accès de secours peut exister pour rétablir un service, jamais pour transmettre des fonds.	Inventaire des accès de secours ; toute utilisation ouvre un dossier d'incident.
4.7	Les accès des partenaires-distributeurs sont limités au provisionnement et à la gestion de leurs propres abonnés ; ils n'ouvrent ni le compte en fiducie ni le grand livre.	Essai fondé sur un scénario, annuel : tentative d'accès croisé entre locataires.

5. Clés d'interface et secrets

N°	Règle	Vérification
5.1	Une clé d'interface appartient à un seul abonné et ne porte que sur ses données. Le cloisonnement est appliqué par la plateforme et non par l'appelant.	Essai d'accès croisé, annuel.
5.2	Toute clé a une durée de vie limitée et est remplacée périodiquement. Le remplacement se fait sans interruption : deux clés peuvent coexister le temps de la bascule.	Âge de la clé la plus ancienne, relevé à la revue trimestrielle.
5.3	Toute clé est révocable immédiatement , par une personne, sans passer par un tiers ni attendre une fenêtre de mise en service.	Révocation exercée lors de l'essai fondé sur un scénario de compromission.
5.4	Aucun secret — clé, mot de passe, jeton, chaîne de connexion — n'est inscrit dans le code source, dans un fichier de configuration versionné, ni transmis par courriel ou messagerie.	Analyse automatisée du dépôt à chaque intégration ; toute occurrence entraîne la révocation du secret trouvé.
5.5	Les secrets sont conservés dans un magasin dédié, chiffrés au repos, accessibles aux seuls services qui en ont besoin.	Inventaire des secrets et de leurs porteurs, revu semestriellement.

6. Postes de travail et appareils

N°	Règle	Vérification
6.1	Tout poste servant à accéder à la production est chiffré intégralement , verrouillé automatiquement et doté d'un effacement à distance.	Inventaire des postes et de leur état de conformité, revu trimestriellement.
6.2	Aucune donnée de production n'est conservée localement. Les extractions nécessaires sont chiffrées, horodatées, journalisées et détruites après usage.	Journal des extractions, examiné à la revue trimestrielle.
6.3	Les postes reçoivent les misés à jour de sécurité selon les délais du chapitre 8 et portent une protection contre les programmes malveillants, à jour.	État de mise à jour relevé au même rythme que les correctifs.

N°	Règle	Vérification
6.4	Aucun support amovible n'est employé en production.	Règle appliquée par configuration du poste.

7. Réseaux, chiffrement et cloisonnement

N°	Règle	Vérification
7.1	Toute communication est chiffrée en transit , y compris entre composants internes et avec l'hébergeur. Le périmètre n'est pas traité comme un réseau de confiance.	Configuration vérifiée à chaque mise en service ; absence de canal en clair contrôlée à l'essai semestriel.
7.2	Les données sont chiffrées au repos : bases de données, sauvegardes, journaux, images de machines.	Inventaire des dépôts de données et de leur état de chiffrement.
7.3	Les environnements de développement, d'essai et de production sont séparés ; aucune donnée de production ne se trouve hors production.	Essai relatif aux modifications, avant chaque mise en service.
7.4	Les accès d'administration sont restreints par provenance et journalisés.	Journal des accès d'administration, revu trimestriellement.
7.5	La transmission des fichiers à l'institution financière parraine emprunte le canal convenu à l'entente , et lui seul.	Canal et empreintes vérifiés à la certification technique, puis à chaque changement.

8. Vulnérabilités et correctifs

Le délai applicable court à partir du moment où le demandeur est informé de la vulnérabilité et a établi qu'il y est exposé, selon la démarche décrite à la note 13 de la pièce 05.

Gravité	Délai de correction	Précisions
Critique	Sans délai, et au plus 48 heures	Vulnérabilité exploitée activement, ou touchant l'accès aux fonds, au grand livre ou à la production des fichiers. À défaut de correctif, une mesure d'atténuation est appliquée dans le même délai.
Élevée	7 jours civils	Exposition établie sans exploitation connue.
Moyenne	30 jours civils	Traitée au cycle courant de mise à jour.
Faible	Au prochain cycle	Consignée et suivie ; sans échéance ferme.

- Les **dépendances applicatives**, y compris celles dont dépendent d'autres bibliothèques, sont inventoriées et suivies ; un composant qui n'est plus maintenu par son éditeur est traité comme une vulnérabilité élevée jusqu'à son remplacement.
- Un correctif appliqué à un actif classé critique à la section 4 de la pièce 05 fait l'objet d'un **essai relatif aux modifications** avant mise en service, sauf lorsque le délai critique l'interdit ; dans ce cas, l'essai suit immédiatement.

9. Développement et mise en service

N°	Règle	Vérification
9.1	Toute modification du code est revue par une seconde personne avant intégration. La revue porte notamment sur les chemins qui produisent une écriture au grand livre ou un enregistrement du fichier de la norme 005.	Historique des revues conservé avec le code.
9.2	Un jeu d'essais automatisé couvre le format du fichier 005 et l'invariant du grand livre. Aucune mise en service n'a lieu si l'un des deux échoue.	Résultat des essais conservé pour chaque mise en service.
9.3	Aucune donnée de production n'est employée en développement ni en essai. Les jeux d'essai sont synthétiques.	Contrôle à la revue de code et à l'essai relatif aux modifications.
9.4	Toute mise en service est réversible : la version précédente demeure déployable, et la procédure de retour en arrière est écrite avant la mise en service, non pendant l'incident.	Retour en arrière exercé au moins une fois par an, dans le cadre des essais.
9.5	Une modification importante des systèmes ou des politiques est approuvée par le cadre dirigeant et déclenche la mise à jour du cadre de gestion des risques.	Registre des modifications importantes et des approbations.

10. Journalisation, surveillance, sauvegardes

N°	Règle	Vérification
10.1	Sont journalisés, de façon attribuable et horodatée : les authentifications et les refus, les actions d'administration, les changements d'état d'une opération et d'un lot, les écritures au grand livre, les accès aux données de contrepartie, les changements de droits et de configuration.	Reconstitution d'un trajet complet, exercée à l'essai annuel.
10.2	Les journaux sont conservés hors de portée des comptes qu'ils observent ; leur altération ou leur suppression est traitée comme un incident.	Droits d'accès aux journaux revus trimestriellement.
10.3	Les journaux et la piste d'audit sont conservés sept ans au Canada .	Politique de conservation vérifiée à l'examen annuel.
10.4	Les sauvegardes sont chiffrées , conservées au Canada, et leur restauration est mise à l'essai semestriellement — la mise à l'essai comprend la reconstitution du grand livre et la confirmation de l'invariant du grand livre.	Résultat de la restauration consigné : date, portée, écart constaté.
10.5	La cible de rétablissement est de quatre heures ouvrables , sans perte de données, conformément à la section 2 de la pièce 05.	Délai et point de reprise constatés à chaque essai et à chaque incident.

11. Données

- **Classification** — les actifs et leur sensibilité sont recensés à la section 4 de la pièce 05. Les données de contrepartie sont réputées sensibles quel que soit leur volume.
- **Cloisonnement** — toute lecture est bornée au locataire qui la demande ; le cloisonnement est appliqué par la plateforme et fait l'objet d'un essai annuel d'accès croisé.
- **Résidence** — les données et les sauvegardes demeurent au Canada, en vertu d'une entente écrite avec l'hébergeur.
- **Minimisation** — le demandeur ne collecte des contreparties que ce qu'exige l'exécution du paiement et la preuve de l'entente.
- **Effacement** — les données personnelles d'une contrepartie peuvent être anonymisées sur demande, sans toucher aux écritures comptables, qui demeurent nécessaires à la piste d'audit financière.

12. Personnes et tiers

Personnes

- La **formation** au présent document et au programme de conformité précède l'octroi de tout accès de production, et se répète annuellement.
- Un **engagement de confidentialité** écrit lie chaque personne ayant accès aux données d'abonnés ou de contreparties.
- Le **signalement** d'un doute — courriel suspect, comportement inattendu d'un système, geste posé par erreur — est attendu sans délai et n'expose son auteur à aucune sanction. Un cadre qui punit la déclaration obtient moins de déclarations, non moins d'incidents.

Tiers

- Toute entente avec un tiers qui héberge, traite ou transmet des données du demandeur prévoit la **résidence au Canada**, la **journalisation**, l'**obligation de signaler** tout incident sans délai, et le droit d'obtenir la preuve des mesures annoncées.
- Les tiers sont **évalués avant l'engagement** et au moins annuellement par la suite.
- Un tiers défaillant est traité selon la procédure 5.4 de la pièce 06.

13. Exceptions, vérification et révision

Les exceptions se comptent. Une dérogation à une règle du présent document est accordée par le cadre dirigeant, par écrit, pour une **durée déterminée**, avec la mesure compensatoire retenue et la date de retour à la conformité. Une dérogation qui vient à échéance sans être renouvelée devient une lacune, consignée à ce titre et présentée à l'examen annuel. Aucune dérogation n'est admise aux règles 4.2, 4.6 et 9.2 — deuxième facteur, interdiction de contourner la double approbation, et jeu d'essais avant mise en service.

- **Vérification** — les colonnes « vérification » du présent document sont exécutées selon le calendrier de la section 12 de la pièce 05 : rapprochement quotidien, revue des accès trimestrielle, vérification des contrôles et restauration semestrielles, essais fondés sur des scénarios annuels.

- **Révision** — le présent document est révisé au moins une fois par année, et après toute modification importante des systèmes, tout incident de gravité G1 ou G2, et toute constatation de l'examen indépendant.
- **Approbation** — chaque version est approuvée par le cadre dirigeant, datée et conservée ; les versions antérieures demeurent accessibles.

Documents liés. Cadre de gestion des risques opérationnels : pièce 05. Cadre de réponse aux incidents : pièce 06. Description des services et des processus de paiement : question 6.1. Diagrammes des processus de paiement : question 6.3. Contrats avec les tiers et procédure de supervision : section 13. Programme de conformité : section 16.

Notes de rédaction — à retirer avant le dépôt

Point	À faire
Délais de correction	Les quatre délais du chapitre 8 sont proposés. Les arrêter, et vérifier qu'ils sont tenables avec les ressources prévues à la section 3 de la pièce 05 avant de les inscrire dans un document déposé.
Règles supposant un outillage	Les règles 5.4 (analyse du dépôt à la recherche de secrets), 6.1 (effacement à distance) et 10.2 (journaux hors de portée) supposent des outils en place. Confirmer qu'ils le sont, ou reformuler la règle au futur et l'assortir d'une échéance.
Deuxième personne	Les règles 4.3 et 9.1 supposent une seconde personne habilitée. Même dépendance qu'aux pièces 05 et 06 : à nommer avant l'activation de la fonction de paiement.
Fréquences	Trimestrielle pour les accès, semestrielle pour les contrôles et les restaurations, annuelle pour les scénarios : aligner ces fréquences sur le calendrier de la section 12 de la pièce 05 si celui-ci est modifié.
Hébergeur	Plusieurs règles renvoient à l'entente d'hébergement — résidence, journalisation, signalement. Les reporter au contrat au moment de retenir l'hébergeur, faute de quoi elles demeurent des intentions.
Nombre de pièces	Les pièces 05, 06 et 07 forment ensemble le cadre exigé à l'article 5 du Règlement. Confirmer que la Banque accepte cette présentation, ou les réunir avant le dépôt.